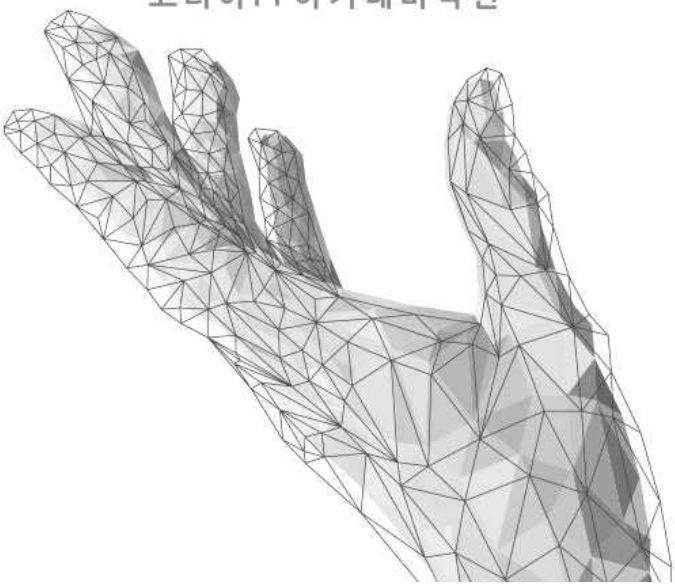
시스템 보안 구축

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 시스템 보안요구사항 정의 및 요구사항 ····· 3
Ⅱ. 시스템 보안요구사항 표 ····· 4
Ⅲ. 시스템 보안 설계 대상 ····· 5
Ⅳ. 시스템 보안 설계 작성 및 패스워드 관리에 대한 설계 ····· 6
가. 시스템 보안 설계 ····· 6
나. 패스워드 관리 설계 ····· 8
Ⅴ. 시스템 보안 구현을 위한 일정 계획 수립 ····· 9
가. 시스템 보안 구현의 추진 목표 설정 방법 ····· 9
나. 추진 목표에 따른 추진 범위 및 수행 업무 세분화 방법 ····· 9
다. 조직 및 역할 정의의 필요성과 구체적 방안 ····· 9
라. 추진 일정 수립 시 고려해야 할 세부 활동과 작성 방법 ····· 9
Ⅵ. WBS 작성 ····· 10
Ⅶ. 루트(root) 계정 원격 접속 제한 ····· 10
Ⅷ. 리눅스 기본 계정에 대한 이해와 관리 ····· 12
가. 운영체제 기본 계정 중 미사용 계정 제거 ····· 12
나. 삭제한 계정 제거 이유 ····· 13
Ⅸ. 로그인 실패 횟수 제한하여 계정 보호 ····· 14
가. 계정 잠금 임계값 설정 ····· 14
Ⅹ. 세션 유지 시간 설정 ····· 17
가. 세션 유지 시간 설정 방법 ····· 17
나. 세션 유지 시간 보안성 ····· 18
Ⅺ. 패스워드 최소 길이 설정 ····· 19
Ⅻ. 패스워드 최대 사용 기간 설정 ····· 20
XIII. 권한 상승 공격 가능성 ····· 21
XIV. 세션 관리 구현 테스트 ····· 23
XVI. 침해여부 확인 및 취약점 문제 해결 ····· 26

Ⅰ. 시스템 보안요구사항 정의 및 요구사항

1) 계정 관리

- 정의: 시스템이 사용자를 식별하기 위해 부여하는 가장 기본적인 인증 수단이며, 특정 사용자에게 귀속된 파일, 자원 및 정보를 관리하는 것.
- 목적: 적절한 권한을 가진 정당한 사용자인지 식별하고, 시스템 내 자원에 대한 소유권을 명확히 하여 보안의 기틀을 마련함.
- 요구사항: 사용자의 신분 변동 발생 시, 해당 계정의 접근 권한을 변동 발생 시점으로부터 24시간 이내에 차단 또는 삭제해야 함.

2) 패스워드 관리

- 정의: 사용자 ID와 함께 입력하여 정당한 사용자임을 증명하는 고유의 문자열로, 비인가자의 데이터베이스나 파일 접속을 차단하는 안전 대책.
- 목적: 등록된 정보와 대조하여 일치 여부를 확인함으로써 서비스 접속을 통제하고, 허가되지 않은 접근으로부터 데이터와 통신망을 보호함.
- 요구사항: 패스워드는 타인의 도용을 방지하기 위해 충분한 길이(가령, 10자리)와 복잡성(가령, 영문 대소문자, 숫자, 특수문자 조합)을 갖추어야 하고, 주기적으로(가령, 3개월마다) 변경해야 함.

3) 세션 관리

- 정의: 망 환경에서 사용자 간 또는 컴퓨터 간의 대화를 위한 논리적 연결 혹은 컴퓨터의 프로세스들 사이에서 통신하기 위해 메시지를 교환하여 서로를 인식한 이후부터 통신을 마칠 때까지의 기간을 의미.
- 목적: 사용자와 시스템 또는 두 시스템 간의 활성화된 접속에 대한 관리로서, 일정 시간이 지날 경우 적절히 세션을 종료하고, 비인가자에 의한 세션 가로채기를 통제함.
- 요구사항: 사용자 단말기에서 일정 시간 동안 활동이 없을 경우 세션을 자동으로 종료해야 하며, 최대 유휴 시간(Idle Time)은 15분을 초과할 수 없음.

4) 접근 제어

- 정의: 접근이란 일반적으로 데이터를 얻는 것으로 데이터가 있는 곳을 알아내어 그곳에 가서 데이터를 가져오는 것을 말한다. 혹은 사용자가 컴퓨터 시스템이나 프로그램을 이용하기 위해 최초로 접속을 시도하는 것.
- 목적: 시스템이 연결된 다른 시스템으로부터 적절히 보호되고 꼭 필요한 사람에 의해서만 필요한 서비스를 제공할 수 있도록 전체 시스템 차원에서 접근을 통제함.
- 요구사항: 관리자 페이지 등 중요 시스템 접속은 사전에 허용된 IP 주소 대역에서만 가능하도록 설정하고, 모든 로그인 시도 시 2단계 인증(2FA/MFA)을 필수 적용해야 함.

5) 권한 관리

- 정의: 조직 내 사용자가 자신의 직책과 위치에 따라 갖게 되는 합법적인 권리를 기반으로, 시스템의 각 사용자가 적격한 정보 자산에만 접근할 수 있도록 통제하는 것을 의미
- 목적: 직무 수행의 정당성 부여하여 조직 내 위치에 따른 공식적인 권한을 시스템 상에 구현하여 업무 수행에 필요한 결정권을 보장하고, 비인가 행위 통제해 개인이나 집단이 허용된 범위를 벗어나 자산을 지배하거나 오남용하지 않도록 차단하여 정보 보안의 합법성을 유지함.
- 요구사항: 사용자별 업무 분장에 따라 권한을 차등 부여하며, 퇴직이나 직무 변경 발생 시 24시간 이내에 해당 계정의 권한을 회수하거나 삭제해야 함.

6) 로그 관리

- 정의: 데이터를 기록한 것 혹은 데이터의 인쇄된 기록.
- 목적: 시스템 내부 혹은 네트워크를 통한 외부에서 시스템에 어떤 영향을 미칠 경우 해당 사항을 기록하여 문제 해결 및 예방 활동에 활용됨.
- 요구사항: 접속 기록, 권한 부여 기록 등 주요 보안 로그는 위·변조 방지를 위해 별도의 로그 서버에 실시간 전송하며, 관련 법령에 따라 최소 6개월 이상 보존해야 함.

7) 취약점 관리

- 정의: 취약점 관리는 취약점을 확인, 분류, 치료, 완화하는 주기적인 과정.
- 목적: 시스템은 계정과 패스워드 관리, 세션 관리, 접근제어, 권한 관리 등을 충분히 잘 갖추고도 보안적인 문제가 발생할 수 있는데, 이는 시스템 자체의 결함에 의한 것이다. 이런 시스템 자체의 결함을 체계적으로 관리하는 것.
- 요구사항: 반기별 1회 이상 정기 보안 취약점 점검을 수행하며, 발견된 '위험(High)' 등급 이상의 취약점은 보고서 승인일로부터 14일 이내에 조치 완료해야 함.

II. 시스템 보안요구사항 표

항목	내용
접근 제어	• 접근제어를 수행하는 인터페이스를 최소화해야 한다. • 각 시스템에 대한 접근은 필요한 사람에게만 허용한다. • 각 시스템의 접근에 대해서는 별도의 관리자를 임명하여 설정한다. • 각 시스템에 대한 접근 통제는 접근 통제 목록(ACL: Access Control ist)을 작성하여 관리한다. • 사용자 계정은 최소 8자 이상의 ID를 사용하며, 동일 ID 중복 생성을 금지한다. • 로그인 실패 5회 이상 시 계정을 30분 이상 잠금 처리해야 한다. • 모든 원격 접속은 VPN을 통해서만 허용하며, 미사용 포트는 100% 차단한다. • 접근 권한 검토는 최소 분기 1회(연 4회) 이상 수행해야 한다. • 관리자 계정 접속 시 2단계 인증(MFA)을 의무 적용해야 한다. • 시스템 미사용 시 10분 이내 자동 로그아웃 되도록 설정해야 한다. • 접근 로그는 최소 1년 이상 보관하며, 위·변조 방지를 적용해야 한다. • 외부 접속은 허용된 IP 대역(화이트리스트) 내에서만 가능하도록 설정해야 한다.
권한 관리	• 시스템에 대한 접근권한은 꼭 필요한 사람에게 필요한 권한(가령, 모든 권한, 수정, 읽기 및 실행, 디렉터리 내용 보기, 읽기, 쓰기 등) • 신규 계정 생성 시 기본 권한은 “읽기 전용”으로 설정하고, 추가 권한은 승인 후 부여한다. • 접근권한은 누적된다. • 파일에 대한 접근권한이 디렉터리에 대한 접근권한보다 우선한다. • 허용보다 거부가 우선한다. • 권한 변경 및 부여 이력은 최소 1년 이상 기록 및 보관해야 한다. • 불필요한 권한은 월 1회 이상 점검하여 제거해야 한다. • 관리자 권한 계정 수는 전체 사용자 수의 5% 이내로 제한해야 한다. • 퇴직자 및 휴직자의 계정은 발생 즉시(최대 24시간 이내) 비활성화 또는 삭제해야 한다. • 동일 사용자가 2개 이상의 관리자 권한을 중복 보유하지 않도록 제한해야 한다. • 중요 시스템 접근 권한은 부서장 승인 등 2단계 승인 절차를 거쳐 부여해야 한다.

Ⅲ. 시스템 보안 설계 대상

<table>
<tr><th>항목</th><th>Client</th><th>Network</th><th>Server</th><th>Application</th><th>Data(DB)</th></tr>
<tr><td rowspan="2">인증</td><td>계정 관리</td><td colspan="4">계정 관리, 비밀번호 관리, 복합 인증 적용</td></tr>
<tr><td>복합 인증 관리</td><td colspan="2">접속 인증정보 평문 하드코딩 제한</td><td></td><td></td></tr>
<tr><td rowspan="2">접근 통제</td><td rowspan="2">이석 시 보안 설정, 보조 저장 매체 및 공유 폴더 제한</td><td rowspan="2">망분리, 비인가된 접근 제한, 비업무 접속 제한, 내부망으로 안전한 접속</td><td colspan="3">접속 화면 관리, 접속 세션 관리, 접속 접근 통제 설정</td></tr>
<tr><td>서비스 및 명령어 제한, 관리자 구분 및 권한 관리</td><td></td><td></td></tr>
<tr><td rowspan="2">암호화</td><td rowspan="2">저장 시 암호화</td><td rowspan="2">전송 구간 암호화</td><td colspan="3">비밀번호 암호화</td></tr>
<tr><td></td><td>문서 암호화</td><td>고객 정보 암호화</td></tr>
<tr><td rowspan="3">로깅 감사</td><td rowspan="3"></td><td colspan="4">접속 기록 관리</td></tr>
<tr><td colspan="4">접근 권한 변경 기록</td></tr>
<tr><td colspan="4">시간 동기화</td></tr>
<tr><td rowspan="2">프라이버시</td><td rowspan="2">화면 캡처 기능 제한. 출력, 출력물 워터마킹, 개인정보 점검 및 유출 방지</td><td rowspan="2"></td><td rowspan="2">개인정보 점검 및 유출 방지</td><td>개인정보 표시 제한</td><td></td></tr>
<tr><td>개인정보 노출 방지, 주민등록번호 대체 수단 마련, 화면 캡처 기능 제한</td><td></td></tr>
<tr><td rowspan="3">침해사고 예방 및 대응</td><td rowspan="3">악성코드 관리, 설치 프로그램 제한</td><td colspan="4">보안 가이드라인 준수</td></tr>
<tr><td rowspan="2">유해 트래픽, 이상 패킷 탐지 및 차단, 대외 서비스 보안</td><td colspan="2">취약점 점검 조치</td><td></td></tr>
<tr><td>악성코드 관리</td><td></td><td></td></tr>
</table>

Ⅳ. 시스템 보안 설계 작성 및 패스워드 관리에 대한 설계

가. 시스템 보안 설계

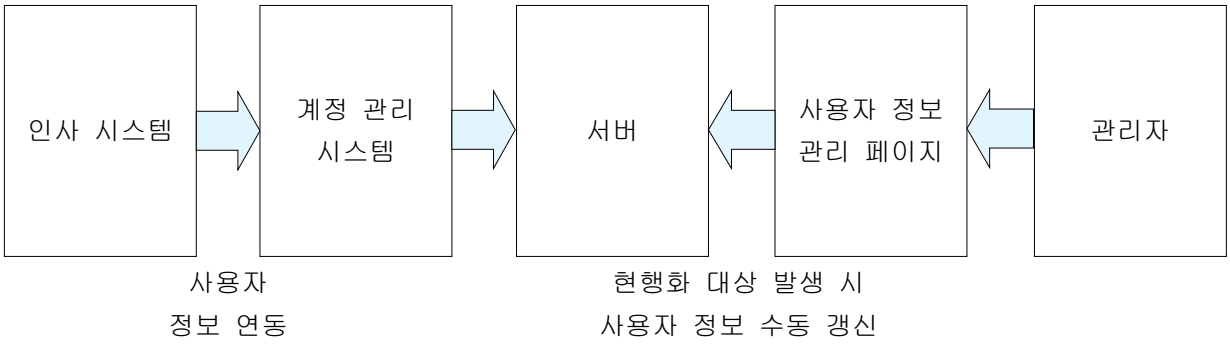
1) 보안 설계 개요

시스템 보안 설계는 시스템 구성 요소 및 정보 자원의 기밀성, 무결성, 가용성(CIA)을 보장하기 위해 수행된다. 시스템 보안이란 외부의 공격(해커, 악성코드, 자연재해 등)과 내부의 위협(불만 사용자, 부정직한 직원 등)으로부터 조직의 컴퓨터 시스템, 데이터베이스, 네트워크 등의 정보 자원을 보호하기 위한 일련의 활동을 의미한다. 이에 따라 본 설계에서는 사용자 인증, 접근제어, 권한관리 등을 중심으로 보안 기능을 정의하고, 비인가 접근을 차단하며 정보 유출을 방지하는 것을 목표로 한다. 또한 최소 권한 원칙과 정기적인 권한 검토를 통해 시스템의 안전성을 지속적으로 유지하도록 한다.

2) 요구사항

항목	내용
계정 및 패스워드 관리	• 필요한 계정에 대해서는 시스템 관리자 및 직책자의 검토 및 승인이 필요함. • 패스워드는 주기적으로(가령, 3개월) 변경해야 함. • 패스워드는 타인의 도용을 방지하기 위해 충분한 길이(가령, 10자리)와 복잡성(가령, 영문 대소문자, 숫자, 특수문자 조합)을 갖추어야 함.
세션 관리	• 세션에 대한 지속적인 인증(continuous authentication)을 해야 함. • PC의 바탕화면에 대한 타임아웃 설정하여 최대 유휴 시간(Idle Time)은 15분을 초과할 수 없음. • 새로운 중요한 거래 시에는 지속적인 인증(가령, 공인인증서의 패스워드 재확인, 보안카드 숫자 재확인 등) 설정
접근 제어	• 접근제어를 수행하는 인터페이스를 최소화해야 함. • 각 시스템에 대한 접근은 필요한 사람에게만 허용 • 모든 로그인 시도 시 2단계 인증(2FA/MFA)을 필수 적용해야 함.
권한 관리	• 시스템에 대한 접근권한은 꼭 필요한 사람에게 필요한 권한(가령, 모든 권한, 수정, 읽기 및 실행, 디렉터리 내용 보기, 읽기, 쓰기 등) • 변경 발생 시 24시간 이내에 해당 계정의 권한을 회수하거나 삭제해야 함. • 파일에 대한 접근권한이 디렉터리에 대한 접근권한보다 우선
로그 관리	• 사용자가 시스템에 로그인하여 명령을 내리는 과정에 대한 시스템의 동작에 대해 인증(authentication), 인가(authorization), 계정(accounting)에 대한 로그 기록 • 로그는 중앙 시스템에 기록하거나, 분산하여 기록 • 접속 기록, 권한 부여 기록 등 주요 보안 로그는 위·변조 방지를 위해 별도의 로그 서버에 실시간 전송하며, 관련 법령에 따라 최소 6개월 이상 보존해야 함.
취약점 관리	• 시스템의 취약점을 보완하기 위해 주기적으로 패치 혹은 서비스 팩 설치 • 주기적으로 시스템의 갱신(update)을 실시 • 시스템 관리 담당자는 주기적으로 시스템 공급자로부터 필요한 패치, 혹은 서비스 팩, 혹은 갱신을 확인하여 14일 이내 필요한 조치를 해야 함.

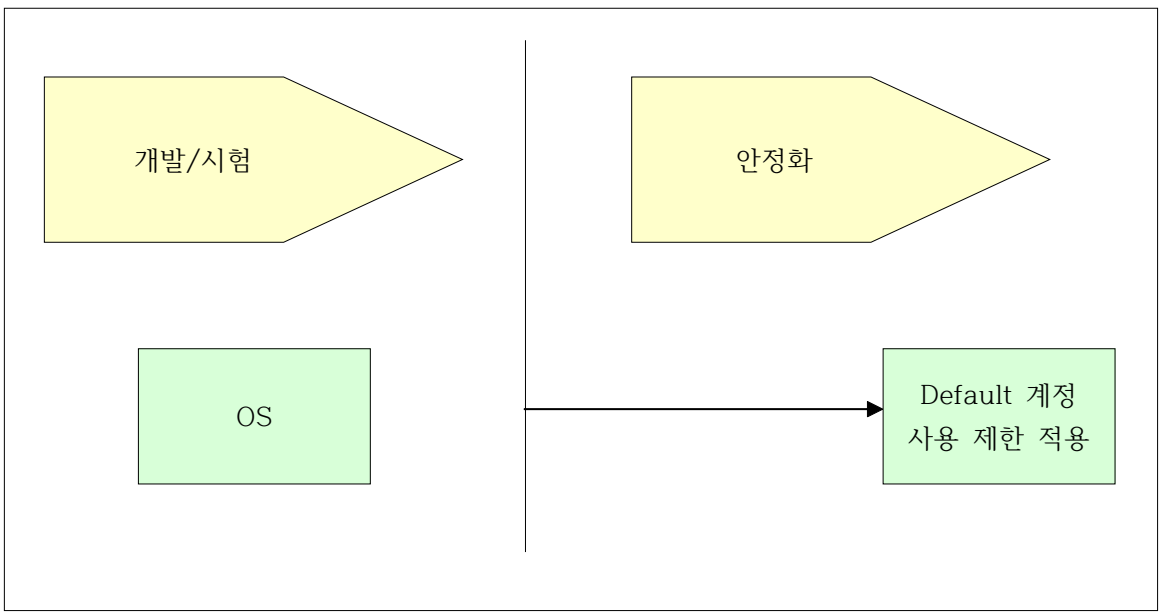
3) 기능 설계



- 주기적 인사 시스템과 연동 (인사이동, 퇴직, 장기출장, 휴직 현행화)
- 사용자 정보 현행화 주기 설정 (가령, 1일 1회)
- 권한 획득, 변경, 해제: 권한 변경 프로세스 수립

4) 관리 계획

- **계정 관리**: 월 1회 계정 정기 점검을 실시하며, 미사용 계정(30일 이상 미접속)을 자동 비활성화한다. 90일(3개월)마다 비밀번호를 바꾸도록 한다. Default 계정을 사용해야 할 경우에는 반드시 비밀번호 변경 후에 사용해야 한다.
- **로그 및 감사**: 로그 보관 기간을 최소 1년으로 하고 이상 접근 탐지 시 즉시 관리자에게 통보하도록 한다. 보안 감사는 연 1회 수행한다.
- **시스템 운영 보안**: 월 1회 OS 및 서버 보안 패치하며 백신은 월 1회, 중요 시스템 접속 시에 2단계 인증을 적용한다.
- **취약점 분석**: 반기별 1회 정기적인 취약점 점검을 실시하며, 'High' 등급 취약점은 발견 후 14일 이내 조치한다.
- **권한 전수 조사:** 매 분기 1회 전체 계정의 권한 적정성을 검토해 불필요한 권한을 회수한다.
- **보안 서약서**: 시스템 관리자 및 사용자를 대상으로 연 1회 보안 서약서를 징구하고 보안 인식 교육을 실시한다.
- **백업 관리**: 보안 설정 및 로그 데이터는 일 단위로 백업하며, 복구 테스트를 연 2회 실시하여 가용성을 보장한다.

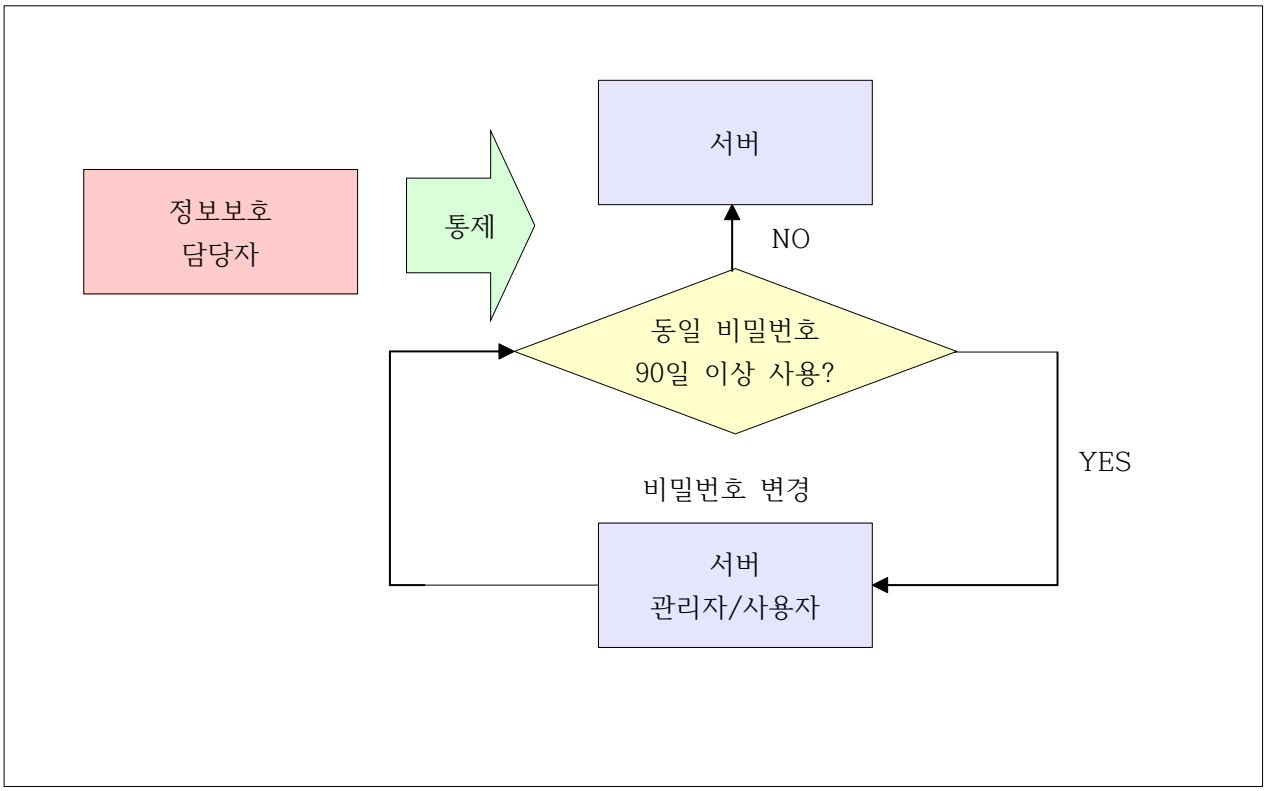


나. 패스워드 관리 설계

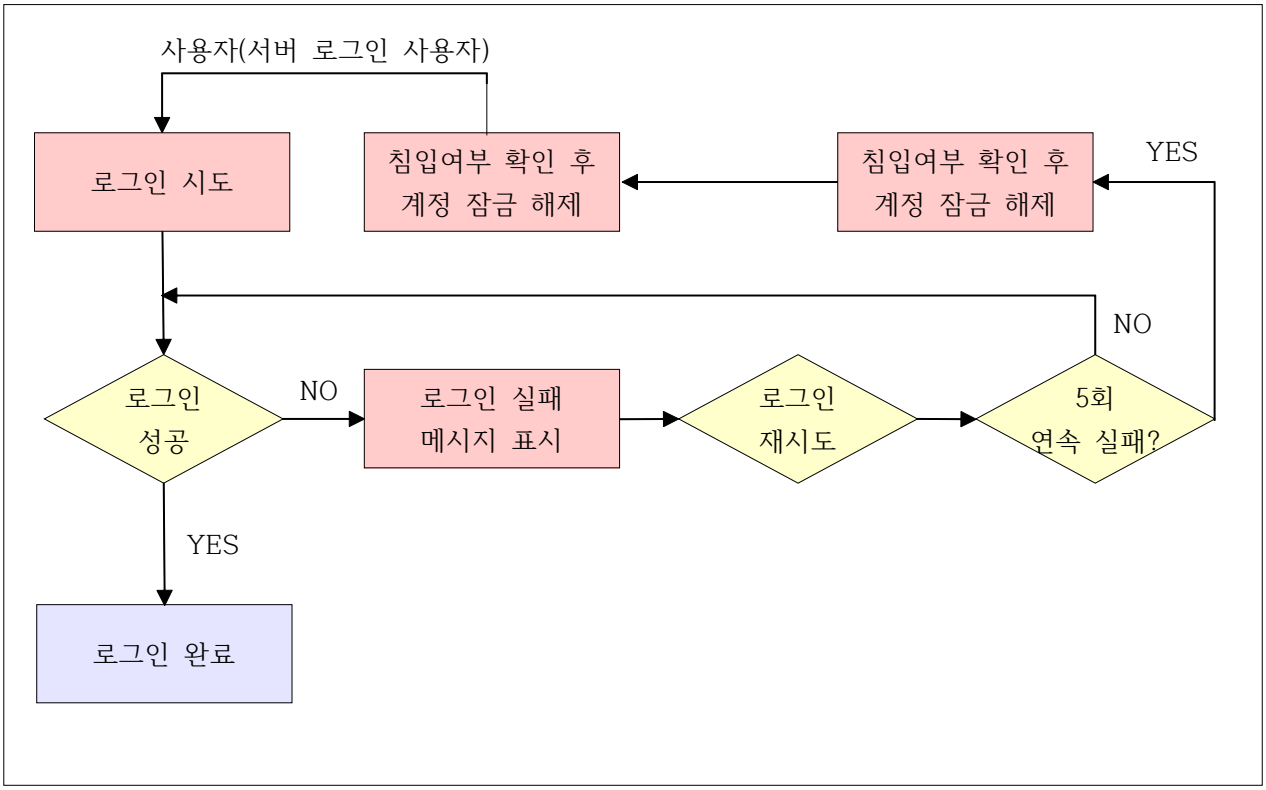
1) 비밀번호 최소 자릿수

구분	패스워드 생성 규칙
규칙	• Null 비밀번호 사용 금지 • 사용자 계정과 동일한 비밀번호 사용 금지 • 자판 배열 순서 단어 사용 금지 • 직전 비밀번호 사용 금지 • 일반 사전 단어 사용 금지
숫자	• 연속 숫자 4자리 이상 사용 금지 • 개인 신상 및 부서 관련 전화번호 사용 금지 • 동일 숫자 및 문자 반복 사용 금지
조합	• 영대문자, 영소문자+숫자+특수문자 중 2종류 조합은 최소 10자리 이상 적용 • 영대문자, 영소문자+숫자+특수분자 중 3종류 조합은 비밀번호 8자리 이상 적용

2) 변경 주기



3) 실패 시 잠금 기준



Ⅴ. 시스템 보안 구현을 위한 일정 계획 수립

가. 시스템 보안 구현의 추진 목표 설정 방법

시스템 보안 구현을 위해서는 먼저 시스템 보안 구현의 추진 목표를 수립할 필요가 있다. 시스템 보안 구현 목표는 조직의 규모 및 특성에 따라 비용 효율적 시스템 보안 구현 혹은 산업 보안에 맞는 최고의 보안 수준을 위한 시스템 보안 구현 등 추진 목표를 설정한다.

나. 추진 목표에 따른 추진 범위 및 수행 업무 세분화 방법

시스템 보안 구현의 추진 범위 및 수행 업무의 세분화는 시스템 보안 구현의 추진 목표에 따라 시스템 보안 구현 범위를 정하고, 시스템 보안 구현 범위에 따라 세부적인 업무 수행 내역(WBS: Work Breakdown Structure)을 작성한다.

다. 조직 및 역할 정의의 필요성과 구체적 방안

시스템 보안 구현을 위한 조직 및 역할은 시스템 보안 구현 범위 및 세부 업무 내역에 따라 시스템 보안 구현을 위한 조직 및 인원을 선정하고, 선정된 인원별로 수행해야 할 업무를 분배한다. 역할별 책임과 권한을 명확히 정의하고, 보고 및 의사소통 체계를 함께 수립해야 한다.

라. 추진 일정 수립 시 고려해야 할 세부 활동과 작성 방법

세부 활동은 시스템 보안 환경 준비를 시작하여 시스템 보안 구현을 종료하는 데 필요한 활동들을 빠짐없이 작성한다. 활동 간 선후 관계와 소요 시간을 고려하여 단계별 일정을 설정한다.

Ⅵ. WBS 작성

대분류	세부 활동	M+0 (1주)	M+0 (2주)	M+0 (3주)	M+0 (4주)	M+1 (1주)	M+1 (2주)	M+1 (3주)	M+1 (4주)	M+2 (1주)	M+2 (2주)	M+2 (3주)	M+2 (4주)
기획	보안 요구사항 정의 및 자산 식별												
기획	현행 시스템 보안 수준 분석												
기획	보안 정책 및 운영 기준 수립												
기획	위험 분석 및 대응 전략 수립												
설계	보안 설계 (네트워크/시스템)												
설계	접근통제 및 인증 구조 설계												
구현	방화벽 및 IPS/IDS 구축												
구현	시스템 보안 설정												
구현	계정 및 권한 관리 시스템 구축												
구현	로그 수집 및 모니터링 시스템 구축												
테스트	취약점 점검 및 모의해킹 수행												
테스트	취약점 보완 및 보안 강화 조치												
운영	최종 보안 점검 및 결과 보고												
운영	운영 정책 적용 및 유지보수 계획 수립												

Ⅶ. 루트(root) 계정 원격 접속 제한

1. SSH 설정 파일 수정

SSH 서비스의 설정 파일을 열어 root 로그인 허용 여부를 변경한다.

```
[rorer@localhost ~]$ su
Password:
[root@localhost rorer]# vi /etc/ssh/sshd_config
```

2. Root 로그인 차단 설정

PermitRootLogin 을 찾아 주석을 지우고 no 로 설정한다.
no 로 설정하면 root 계정의 원격 로그인이 완전 차단된다.

```
PermitRootLogin no
:wq_
```

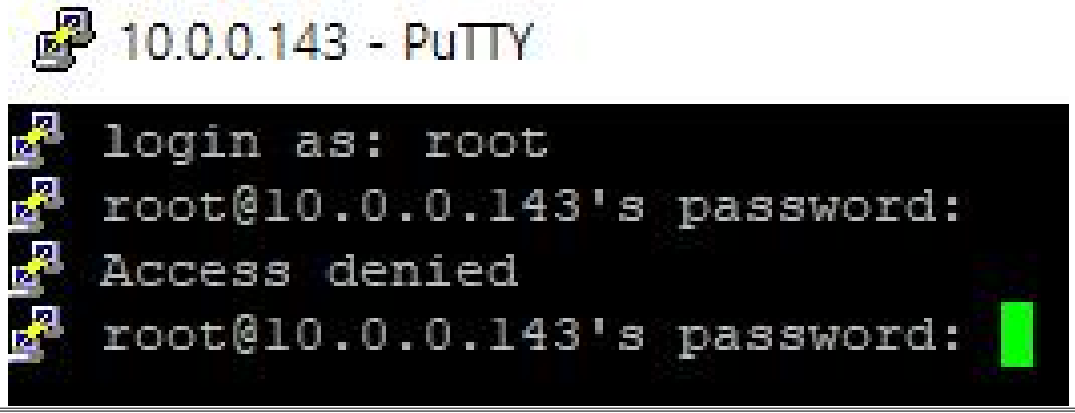
3. SSH 서비스 재시작

설정 적용을 위해 SSH 서비스를 재시작한다.

```
[root@localhost rorer]# systemctl restart sshd
```

4. 적용 확인

PuTTY 를 사용하여 root 계정으로 접속을 시도한다.
로그인 실패 발생하였으므로 root 원격 접속 차단 성공하였다.



Ⅷ. 리눅스 기본 계정에 대한 이해와 관리

가. 운영체제 기본 계정 중 미사용 계정 제거

1. 전체 계정 목록 확인

시스템에 존재하는 모든 사용자 계정을 확인하기 위해 /etc/passwd 파일을 출력한다.
해당 파일에는 사용자 계정 정보가 저장되어 있으며, 기본적으로 생성된 계정들을 확인할 수 있다.

```
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
systemd-network:x:192:192:systemd Network Management:/:/sbin/nologin
dbus:x:81:81:System message bus:/:/sbin/nologin
polkitd:x:999:998:User for polkitd:/:/sbin/nologin
libstoragemgmt:x:998:996:daemon account for libstoragemgmt:/var/run/lsm:/sbin/nologin
rpc:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin
colord:x:997:995:User for colord:/var/lib/colord:/sbin/nologin
saslauth:x:996:76:Saslauthd user:/run/saslauthd:/sbin/nologin
abrt:x:173:173::/etc/abrt:/sbin/nologin
setroubleshoot:x:995:992::/var/lib/setroubleshoot:/sbin/nologin
rtkit:x:172:172:RealtimeKit:/proc:/sbin/nologin
chrony:x:994:991::/var/lib/chrony:/sbin/nologin
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
qemu:x:107:107:qemu user:/:/sbin/nologin
unbound:x:993:990:Unbound DNS resolver:/etc/unbound:/sbin/nologin
gluster:x:992:989:GlusterFS daemons:/var/run/gluster:/sbin/nologin
tss:x:59:59:Account used by the trousers package to sandbox the tcsd daemon:/dev/null:/sbin/nologin
usbmuxd:x:113:113:usbmuxd user:/:/sbin/nologin
geoclue:x:991:987:User for geoclue:/var/lib/geoclue:/sbin/nologin
sysuser:x:0:0::/root:/bin/bash
radvd:x:75:75:radvd user:/:/sbin/nologin
pulse:x:171:171:PulseAudio System Daemon:/var/run/pulse:/sbin/nologin
gdm:x:42:42::/var/lib/gdm:/sbin/nologin
gnome-initial-setup:x:990:984::/run/gnome-initial-setup/:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
avahi:x:70:70:Avahi mDNS/DNS-SD Stack:/var/run/avahi-daemon:/sbin/nologin
postfix:x:89:89::/var/spool/postfix:/sbin/nologin
ntp:x:38:38::/etc/ntp:/sbin/nologin
tcpdump:x:72:72::/:/sbin/nologin
ororor:x:1000:1000:ororor:/home/ororor:/bin/bash
user:x:1001:1001::/home/user:/bin/bash
[root@localhost ororor]# _
```

2. 특정 계정 필터링 및 확인

egrep 명령어를 사용하여 삭제 대상 계정(games, ftp, tcpdump 등)을 필터링하여 확인한다.
이를 통해 전체 계정 중 불필요한 계정을 빠르게 식별할 수 있다.

```
[root@localhost ororor]# cat /etc/passwd | egrep "ssh|game|ftp|tcpdump|ororor"
games:x:12:100:games:/usr/games:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
tcpdump:x:72:72::/:/sbin/nologin
ororor:x:1000:1000:ororor:/home/ororor:/bin/bash
[root@localhost ororor]# _
```

3. 불필요한 계정 삭제

userdel -r 명령어를 사용하여 해당 계정을 삭제한다.
-r 옵션은 계정뿐만 아니라 해당 사용자의 홈 디렉토리까지 함께 제거하여 잔여 파일을 남기지 않도록 한다.

```
[root@localhost roror]# userdel -r games
userdel: group games not removed because it is not the primary group of user games.
userdel: games mail spool (/var/spool/mail/games) not found
userdel: /usr/games not owned by games, not removing
[root@localhost roror]# userdel -r ftp
userdel: ftp mail spool (/var/spool/mail/ftp) not found
userdel: ftp home directory (/var/ftp) not found
[root@localhost roror]# userdel -r tcpdump
userdel: tcpdump mail spool (/var/spool/mail/tcpdump) not found
userdel: / not owned by tcpdump, not removing
[root@localhost roror]#
```

4. 계정 삭제 결과 확인

계정 삭제 후 /etc/passwd 파일을 다시 확인하여 해당 계정들이 정상적으로 삭제되었는지 검증한다.

```
[root@localhost roror]# cat /etc/passwd | egrep "ssh|game|ftp|tcpdump|roror"
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
roror:x:1000:1000:roror:/home/roror:/bin/bash
[root@localhost roror]#
```

나. 삭제한 계정 제거 이유

삭제 계정	삭제 이유
games	• games 계정은 게임 프로그램 실행을 위해 생성되는 기본 계정이다. • 일반적인 서버 환경에서는 게임 관련 기능을 사용하지 않기 때문에 필요하지 않다. • 사용되지 않는 계정이 시스템에 존재할 경우, 공격자가 해당 계정을 이용하여 권한을 획득하거나 시스템 침입에 악용할 수 있으므로 삭제하는 것이 바람직하다.
ftp	• ftp 계정은 FTP(File Transfer Protocol) 서비스를 위해 생성되는 계정이다. • FTP는 데이터가 암호화되지 않고 평문으로 전송되기 때문에 보안에 취약한 프로토콜이다. • 최근에는 SFTP와 같은 안전한 방식이 사용되므로 FTP 계정은 불필요하며, 공격자가 이를 통해 시스템에 접근할 가능성이 있어 삭제해야 한다.
tcpdump	• tcpdump 계정은 네트워크 패킷 분석 도구인 tcpdump 실행을 위해 생성되는 계정이다. • 일반 사용자 환경에서는 패킷 분석 기능을 사용할 일이 거의 없으며, 해당 계정이 존재할 경우 네트워크 정보가 노출될 위험이 있다. • 공격자가 이를 악용하면 트래픽을 분석하거나 중요한 정보를 탈취할 수 있으므로 삭제하는 것이 안전하다.

IX. 로그인 실패 횟수 제한하여 계정 보호

가. 계정 잠금 임계값 설정

1. /etc/pam.d/password-auth 파일 수정

계정 인증 시 로그인 실패 횟수를 제한하기 위해 PAM(Pluggable Authentication Modules) 설정 파일인 /etc/pam.d/password-auth에 접근하여 보안 정책을 적용한다.

```
[root@localhost roror]# vi /etc/pam.d/password-auth
```

2. 로그인 실패 횟수 제한 설정 추가

pam_tally2.so 모듈을 사용하여 로그인 실패 횟수를 5회로 제한하고, 5회 초과 시 계정을 잠그도록 설정하였다. 또한 unlock_time=120 옵션을 통해 120초 후 자동으로 잠금이 해제되도록 구성하였다. 그리고 계정 관리 단계에서 로그인에 성공할 경우 누적된 실패 횟수를 초기화하여 정상 사용자가 다시 로그인할 수 있도록 하였다.

```
#%PAM-1.0
# This file is auto-generated.
# User changes will be destroyed the next time authconfig is run.
auth        required      pam_env.so
auth        required      pam_faildelay.so delay=2000000
auth        sufficient    pam_unix.so nullok try_first_pass
auth        requisite     pam_succeed_if.so uid >= 1000 quiet_success
auth        required      pam_deny.so
auth        required      pam_tally2.so deny=5 unlock_time=120 no_magic_root

account     required      pam_unix.so
account     sufficient    pam_localuser.so
account     sufficient    pam_succeed_if.so uid < 1000 quiet
account     required      pam_permit.so
account     required      pam_tally2.so no_magic_root reset

password    requisite     pam_pwquality.so try_first_pass local_users_only retry=3 authtok_type=
password    sufficient    pam_unix.so sha512 shadow nullok try_first_pass use_authtok


password    required      pam_deny.so

session     optional      pam_keyinit.so revoke
session     required      pam_limits.so
-session     optional      pam_systemd.so
session     [success=1 default=ignore] pam_succeed_if.so service in crond quiet use_uid
session     required      pam_unix.so
```

3. /etc/pam.d/system-auth 파일 수정

시스템 전반의 인증 정책에도 동일한 보안 설정을 적용하기 위해 /etc/pam.d/system-auth 파일을 수정한다. 이 파일은 다양한 인증 과정에 공통적으로 사용되므로 중요한 설정 파일이다.

```
[root@localhost roror]# vi /etc/pam.d/system-auth
```

4. 시스템 전체 로그인 정책 적용

system-auth 파일에도 동일하게 pam_tally2.so 모듈을 추가하여 모든 인증 경로에서 로그인 실패 횟수 제한 정책이 적용되도록 설정하고, 로그인에 성공하면 누적된 실패 횟수를 초기화해 사용자가 다시 로그인할 수 있도록 한다.

```
#%PAM-1.0
# This file is auto-generated.
# User changes will be destroyed the next time authconfig is run.
auth        required      pam_env.so
auth        required      pam_faildelay.so delay=2000000
auth        sufficient    pam_fprintd.so
auth        sufficient    pam_unix.so nullok try_first_pass
auth        requisite     pam_succeed_if.so uid >= 1000 quiet_success
auth        required      pam_deny.so
auth        required      pam_tally2.so deny=5 unlock_time=120 no_magic_root

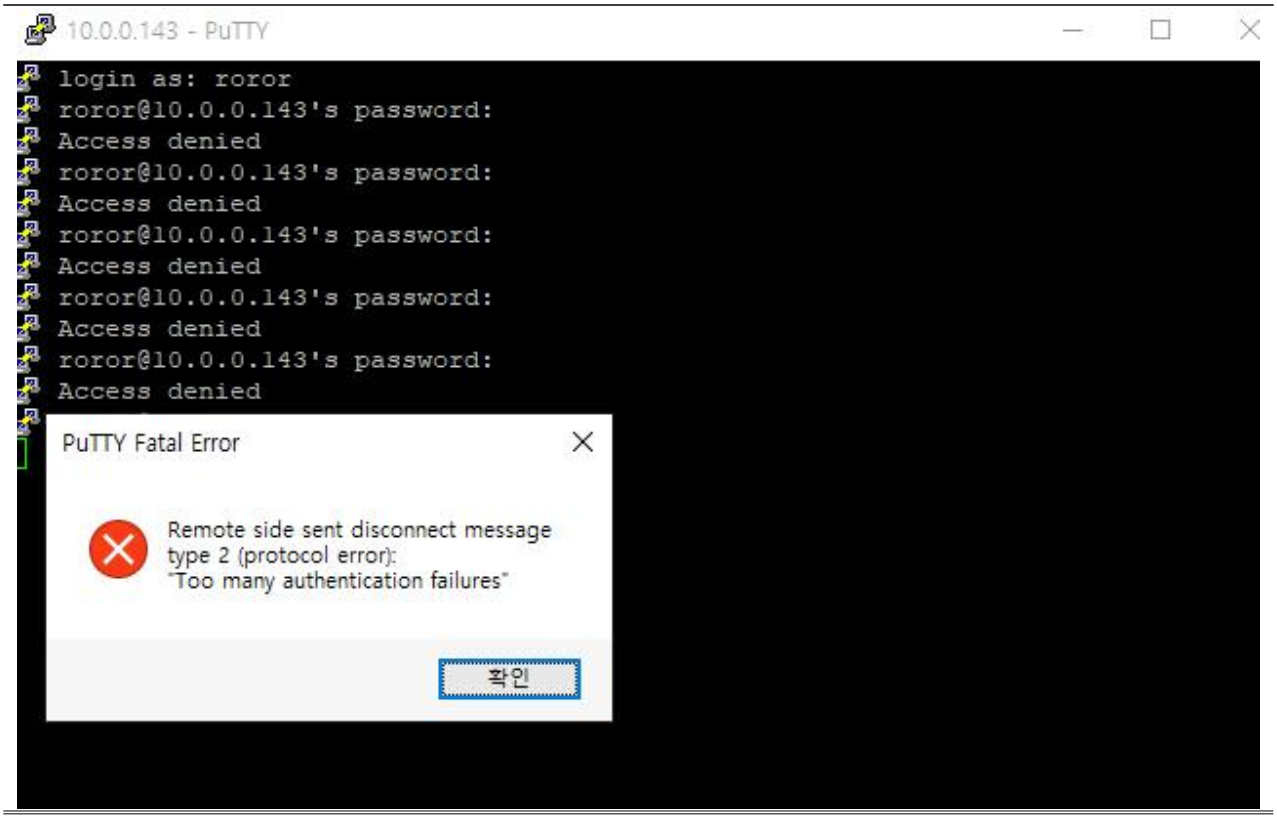
account     required      pam_unix.so
account     sufficient    pam_localuser.so
account     sufficient    pam_succeed_if.so uid < 1000 quiet
account     required      pam_permit.so
account     required      pam_tally2.so no_magic_root reset

password    requisite     pam_pwquality.so try_first_pass local_users_only retry=3 authtok_type=
password    sufficient    pam_unix.so sha512 shadow nullok try_first_pass use_authtok
password    required      pam_deny.so

session     optional      pam_keyinit.so revoke
session     required      pam_limits.so
-session     optional      pam_systemd.so
session     [success=1 default=ignore] pam_succeed_if.so service in crond quiet use_uid
session     required      pam_unix.so
```

5. PuTTY를 이용한 로그인 실패 테스트

원격 접속 도구인 PuTTY를 사용하여 의도적으로 비밀번호를 5회 이상 틀리게 입력하였다. 그 결과, 일정 횟수 초과 시 "Too many authentication failures" 메시지가 출력되며 추가 로그인 시도가 차단되는 것을 확인하였다. 이를 통해 무차별 대입 공격(Brute Force Attack)에 대한 방어가 정상적으로 작동함을 검증하였다.



X. 세션 유지 시간 설정

가. 세션 유지 시간 설정 방법

1. /etc/profile 파일 수정

리눅스 시스템에서 일정 시간 동안 사용자의 입력이 없을 경우 자동으로 로그아웃되도록 하기 위해 /etc/profile 파일을 수정한다.

```
[root@localhost roror]# vi /etc/profile
```

2. 세션 유지 시간(600초) 설정

600초(10분) 동안 입력이 없으면 자동 로그아웃되게 설정하고 이를 모든 사용자 세션에 해당 설정이 적용되도록 한다.

```
TMOUT=600
export TMOUT
```

3. 설정 적용

설정한 환경 변수(TMOUT)를 현재 세션에 즉시 적용하기 위한 명령어로, 재로그인하지 않고도 변경된 설정을 바로 반영할 수 있다.

```
[root@localhost roror]# source /etc/profile
```

※ 계정이 접속된 상태로 방치될 경우 권한이 없는 사용자에게 중요 시스템이 노출되어 악의적인 목적으로 사용될 수 있으므로 일정 시간 이후 어떠한 이벤트가 발생되지 않으면 연결을 종료할 필요가 있다.

나. 세션 유지 시간 보안성

삭제 계정	삭제 이유
세션 하이재킹 (Session Hijacking) 방지	사용자가 공공장소나 공유 PC에서 로그아웃을 하지 않고 자리를 비웠을 때, 세션이 무한정 유지되면 공격자가 해당 세션을 가로채 사용자의 권한을 남용할 수 있습니다. 600초 설정은 이러한 노출 시간을 최소화한다.
불필요한 리소스 점유 방지	서버는 각 세션 정보를 메모리에 저장합니다. 활동하지 않는 세션을 조기에 만료시킴으로써 서버 자원(RAM, CPU)을 효율적으로 관리하고, 결과적으로 서비스 거부 공격(DoS)에 대한 내성을 높인다.
교차 사이트 요청 위조 (CSRF) 노출 감소	브라우저에 세션 쿠키가 남아 있는 시간이 짧을수록, 공격자가 악성 스크립트를 통해 사용자의 의도와 상관없는 요청을 보낼 수 있는 공격 가능 시간(Window of Opportunity)이 줄어든다.

XI. 패스워드 최소 길이 설정

1. /etc/login.defs 파일 수정

리눅스 시스템에서 새로운 계정을 생성하게 된다면 그 계정의 비밀번호 최소 길이를 설정하기 위해 /etc/login.defs 파일을 수정한다.

```
[root@localhost roror]# vi /etc/login.defs
```

2. 비밀번호 최소 길이 설정

비밀번호의 최소 길이를 8자리 이상으로 제한한다.

```
PASS_MAX_DAYS   99999
PASS_MIN_DAYS   0
PASS_MIN_LEN    8
PASS_WARN_AGE   7
```

3. 설정 적용 결과 확인

비밀번호를 8자리 미만으로 설정을 시도하니 “암호는 8개의 문자보다 짧습니다” 메시지가 출력되며 설정이 적용됨을 확인하였다.

```
[root@localhost roror]# useradd user1
[root@localhost roror]# passwd user1
user1 사용자의 비밀 번호 변경 중
새  암호:
잘못된 암호: 암호는 8 개의 문자 보다 짧습니다
새  암호 재입력:
```

XII. 패스워드 최대 사용 기간 설정

1. /etc/login.defs 파일 수정

리눅스 시스템에서 새로운 계정을 생성하게 된다면 그 계정 비밀번호의 최대 사용 기간을 설정하기 위해 /etc/login.defs 파일을 수정한다.

```
[root@localhost roror]# vi /etc/login.defs
```

2. 비밀번호 최대 사용 기간 설정

비밀번호를 최대 90일 동안만 사용하도록 제한하여 일정 기간이 지나면 사용자가 반드시 비밀번호를 변경하도록 강제하여 보안을 강화한다.

```
PASS_MAX_DAYS   90
PASS_MIN_DAYS   0
PASS_MIN_LEN    8
PASS_WARN_AGE   7
```

3. 설정 적용 여부 확인

PASS_MAX_DAYS 90이 출력되며 설정이 정상적으로 적용된 것을 확인하였다.

```
[root@localhost roror]# useradd user2
[root@localhost roror]# passwd user2
user2 사용자의 비밀 번호 변경 중
새  암호:
새  암호 재입력:
passwd: 모든 인증 토큰이 성공적으로 업데이트 되었습니다.
[root@localhost roror]# grep PASS_MAX_DAYS /etc/login.defs
#       PASS_MAX_DAYS   Maximum number of days a password may be used.
PASS_MAX_DAYS   90
```

XIII. 권한 상승 공격 가능성

1. SUID 파일 점검

시스템 전체에서 SUID(Set User ID) 권한이 설정된 파일을 탐색하여 일반 사용자가 root 권한으로 실행 가능한 파일을 점검한다.

```
[root@localhost roror]# find / -perm -4000 -type f -ls 2>/dev/null
50470033   32 -rwsr-xr-x   1 root     root        32008  4월 11  2018 /usr/bin/fusermo
unt
50864167   28 -rwsr-xr-x   1 root     root        27832  6월 10  2014 /usr/bin/passwd
51016913   24 -rws--x--x   1 root     root        24048  4월 11  2018 /usr/bin/chfn
51016916   24 -rws--x--x   1 root     root        23960  4월 11  2018 /usr/bin/chsh
51016200   64 -rwsr-xr-x   1 root     root        64240 11월  6  2016 /usr/bin/chage
51016201   80 -rwsr-xr-x   1 root     root        78216 11월  6  2016 /usr/bin/gpasswd
51016203   44 -rwsr-xr-x   1 root     root        41776 11월  6  2016 /usr/bin/newgrp
51016964   32 -rwsr-xr-x   1 root     root        32184  4월 11  2018 /usr/bin/su
51016949   44 -rwsr-xr-x   1 root     root        44320  4월 11  2018 /usr/bin/mount
51017453 2356 -rwsr-xr-x   1 root     root      2409344  4월 12  2018 /usr/bin/Xorg
51016968   32 -rwsr-xr-x   1 root     root        32048  4월 11  2018 /usr/bin/umount
51019119   60 -rwsr-xr-x   1 root     root        57576  4월 11  2018 /usr/bin/crontab
51017247   28 -rwsr-xr-x   1 root     root        27680  4월 11  2018 /usr/bin/pkexec
51738886   52 -rwsr-xr-x   1 root     root        52952  4월 11  2018 /usr/bin/at
51744218  140 ---s--x--x   1 root     root       143184  4월 11  2018 /usr/bin/sudo
51740437  200 ---s--x---   1 root     stapusr    203832  4월 13  2018 /usr/bin/staprun
17819998   12 -rwsr-xr-x   1 root     root         8544  9월 22  2021 /usr/bin/vim
```

2. SUID 및 SGID 파일 통합 점검

SUID와 SGID(Set Group ID) 권한이 설정된 파일을 모두 탐색하여 권한 상승 공격에 악용될 수 있는 파일을 확인한다.

```
[root@localhost roror]# find / \( -perm -4000 -o -perm -2000 \) -type f -ls 2>/dev/null
50470033   32 -rwsr-xr-x   1 root     root        32008  4월 11  2018 /usr/bin/fusermount
50525950   16 -r-xr-sr-x   1 root     tty         15344  6월 10  2014 /usr/bin/wall
50864167   28 -rwsr-xr-x   1 root     root        27832  6월 10  2014 /usr/bin/passwd
51016913   24 -rws--x--x   1 root     root        24048  4월 11  2018 /usr/bin/chfn
51016916   24 -rws--x--x   1 root     root        23960  4월 11  2018 /usr/bin/chsh
51016200   64 -rwsr-xr-x   1 root     root        64240 11월  6  2016 /usr/bin/chage
51016201   80 -rwsr-xr-x   1 root     root        78216 11월  6  2016 /usr/bin/gpasswd
51016203   44 -rwsr-xr-x   1 root     root        41776 11월  6  2016 /usr/bin/newgrp
51016964   32 -rwsr-xr-x   1 root     root        32184  4월 11  2018 /usr/bin/su
51016949   44 -rwsr-xr-x   1 root     root        44320  4월 11  2018 /usr/bin/mount
51017453 2356 -rwsr-xr-x   1 root     root      2409344  4월 12  2018 /usr/bin/Xorg
51016968   32 -rwsr-xr-x   1 root     root        32048  4월 11  2018 /usr/bin/umount
51019119   60 -rwsr-xr-x   1 root     root        57576  4월 11  2018 /usr/bin/crontab
51016974   20 -rwxr-sr-x   1 root     tty         19624  4월 11  2018 /usr/bin/write
51017247   28 -rwsr-xr-x   1 root     root        27680  4월 11  2018 /usr/bin/pkexec
51061711  376 ---x--s--x   1 root     nobody     382240  4월 11  2018 /usr/bin/ssh-agent
51738886   52 -rwsr-xr-x   1 root     root        52952  4월 11  2018 /usr/bin/at
51744218  140 ---s--x--x   1 root     root       143184  4월 11  2018 /usr/bin/sudo
51735031   40 -rwx--s--x   1 root     slocate     40520  4월 11  2018 /usr/bin/locate
51740437  200 ---s--x---   1 root     stapusr    203832  4월 13  2018 /usr/bin/staprun
17819998   12 -rwsr-xr-x   1 root     root         8544  9월 22  2021 /usr/bin/vim
360549   12 -rwsr-xr-x   1 root     root        11216  4월 11  2018 /usr/sbin/pam_timestamp_check
360551   36 -rwsr-xr-x   1 root     root        36280  4월 11  2018 /usr/sbin/unix_chkpwd
```

3. 핵심 취약점

17819998 12 -rwsr-xr-x 1 root root 8544 9월 22 2021 /usr/bin/vim

4. 문제점

vim은 텍스트 에디터이지만, 내부에서 쉘(Shell) 명령을 실행할 수 있는 기능을 가지고 있다. 여기에 SUID가 있으면 일반 사용자가 vim을 실행하면 root 권한으로 에디터가 구동된다. 일반 사용자가 vim 실행 후 :! /bin/sh 를 입력하면 즉시 root 쉘을 얻게 된다. 이는 전형적인 권한 상승 통로이다.

5. 취약 권한 제거 조치

/usr/bin/vim 파일의 특수 권한이 제거되어 일반 사용자 권한으로 실행되도록 변경되었다.

- chattr -i : immutable 속성이 설정되어 있을 경우 권한 변경 가능하도록 해제한다.
- chmod 755 : SUID/SGID 비트를 제거하고 일반 실행 권한으로 변경한다.

```
[root@localhost roror]# chattr -i /usr/bin/vim
[root@localhost roror]# chmod 755 /usr/bin/vim
```

6. 조치 결과 확인 확인

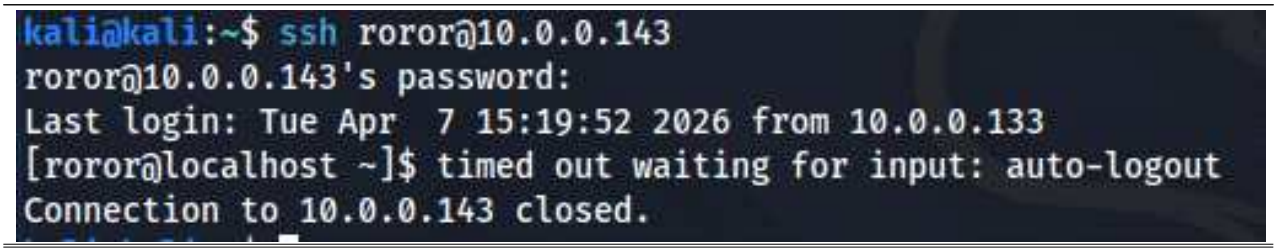
파일 권한을 확인하여 SUID/SGID 비트가 제거되었는지 검증하여 -rwxr-xr-x 형태로 표시되며, SUID 비트(s)가 제거된 것을 확인하였다.

```
[root@localhost roror]# ls -l /usr/bin/vim
-rwxr-xr-x. 1 root root 8544  9월  22  2021 /usr/bin/vim
```

XIV. 세션 관리 구현 테스트

1. 테스트 결과

kali 를 이용하여 원격 서버에 접속 후 일정 시간 동안 아무 입력 없이 대기 하였다. 일정 시간이 지난 후 세션이 자동 종료되는 것을 확인하였다.



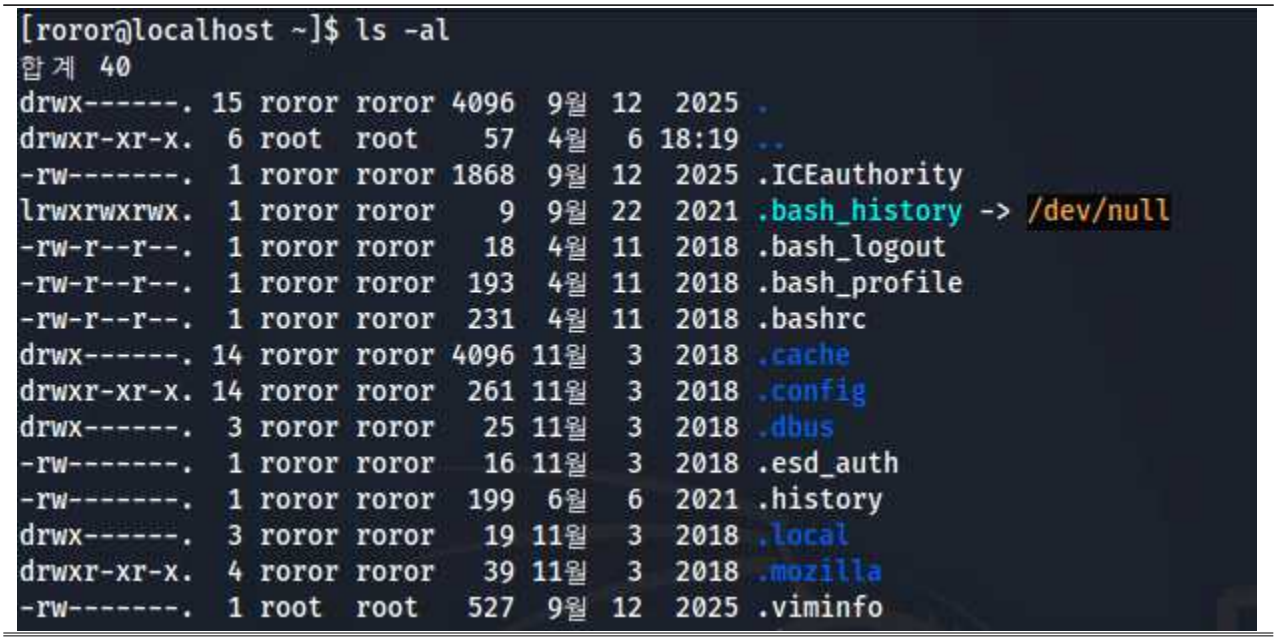
2. 결과 분석

- 설정한 세션 유지 시간(600초)이 정상적으로 적용됨
- 사용자 입력이 없는 경우 자동으로 로그아웃 처리됨
- 비활성 세션이 자동 종료되도록 설정되어 있어 세션 탈취 및 무단 접근 위험을 효과적으로 방지할 수 있음
- 따라서 시스템 보안을 위한 세션 관리가 정상적으로 구현되었음

XV. history 결함여부 및 결함 해결

1. 현재 상태 확인

홈 디렉토리 내 파일 목록을 확인하여 .bash_history 파일 존재 여부 및 권한 상태를 점검한다. .bash_history 파일이 아닌 심볼릭 링크(symbolic link) 상태이다.



2. 문제점

- 사후 분석 불가: 만약 시스템에 문제가 생겼거나 해킹을 당했을 때, 누가 어떤 명령어를 입력해서 사고가 났는지 추적할 방법이 아예 사라진다.
- 작업 효율성 저하: 이전에 입력했던 긴 명령어들을 위쪽 화살표 키를 눌러 다시 불러오거나 history 명령어로 확인할 수 없다. 세션이 종료되면 모든 기록이 날아간다.
- 실수 복구 불가능: 실행했던 명령어가 뭐였는지 확인해야 할 때 아무런 도움을 받을 수 없다.

3. 의심되는 상황

- 침입자의 흔적 지우기: 해커가 침투한 후 자신의 작업 기록을 남기지 않기 위해 의도적으로 연결해 두었을 가능성이 있다.
- 개인정보 보호 설정: 공용 계정 등에서 보안상 기록을 남기지 않으려고 의도적으로 설정했을 수 있습니다.

4. 기존 history 파일 삭제

제거 후 재생성하기 위해 기존 .bash_history 파일을 삭제한다.

```
[rorer@localhost ~]$ rm /home/rorer/.bash_history
```

5. 삭제 확인

.bash_history 파일이 정상적으로 삭제되었는지 확인한다.

```
[rorer@localhost ~]$ ls -al
합계 40
drwx------. 15 rorer rorer 4096  4월  7 16:06 .
drwxr-xr-x.  6 root  root    57  4월  6 18:19 ..
-rw-------.  1 rorer rorer 1868  9월 12  2025 .ICEauthority
-rw-r--r--.  1 rorer rorer   18  4월 11  2018 .bash_logout
-rw-r--r--.  1 rorer rorer  193  4월 11  2018 .bash_profile
-rw-r--r--.  1 rorer rorer  231  4월 11  2018 .bashrc
drwx------. 14 rorer rorer 4096 11월  3  2018 .cache
drwxr-xr-x. 14 rorer rorer  261 11월  3  2018 .config
drwx------.  3 rorer rorer   25 11월  3  2018 .dbus
-rw-------.  1 rorer rorer   16 11월  3  2018 .esd_auth
-rw-------.  1 rorer rorer  199  6월  6  2021 .history
drwx------.  3 rorer rorer   19 11월  3  2018 .local
drwxr-xr-x.  4 rorer rorer   39 11월  3  2018 .mozilla
-rw-------.  1 root  root   527  9월 12  2025 .viminfo
-rw-r--r--.  1 root  root    82  9월 22  2021 vim.c
```

6. history 파일 재생성

bash shell에서 명령어 기록을 저장하기 위한 새로운 .bash_history 파일을 생성한다.

```
[roror@localhost ~]$ touch /home/roror/.bash_history
```

7. 생성 확인

.bash_history 파일이 정상적으로 생성되었는지 확인한다.

```
[roror@localhost ~]$ ls -al | grep "bash_history"
-rw-rw-r--.  1 roror roror    0  4월   7 16:14 .bash_history
```

8. 권한 설정

파일 권한을 600 (rw-------) 으로 설정하여 소유자만 읽기/쓰기 가능하도록 제한한다.

```
[root@localhost roror]# chmod 600 /home/roror/.bash_history
[root@localhost roror]# ls -al | grep "bash_history"
-rw-------.  1 roror roror    0  4월   7 16:14 .bash_history
```

XVI. 침해여부 확인 및 취약점 문제 해결

1. 침해 여부 확인

- S (File Size): 파일 크기 변경됨
- 5 (MD5 Checksum): 파일의 해시값(내용물) 변경됨
- T (Mtime): 수정 시간 변경됨

/usr/bin/vim 파일이 정상 패키지와 다르게 변조되었다.

```
[root@localhost roror]# rpm -V vim-enhanced
S.5....T.    /usr/bin/vim
```

2. 침해 분석

- 시스템 기본 편집기인 vim이 변조되었다.
- 악성코드 또는 백도어 삽입되었을 가능성이 있다.
- 시스템 권한이 탈취 당할 위험이 있다.
- 사용자 정보가 유출되었을 가능성이 있다.

3. 정상 소스로 재컴파일

gcc 컴파일러를 사용하여 vim.c라는 소스 파일로부터 vim이라는 이름의 실행 파일을 생성하여 침해된 바이너리 파일을 삭제하고 깨끗한 실행 파일을 다시 만든다.

```
[root@localhost roror]# gcc vim.c -o vim
```

4. 기존 vim 파일 교체

정상적인 vim 파일을 시스템 바이너리 경로인 /usr/bin/vim 으로 이동시킨다.

```
[root@localhost roror]# mv ./vim /usr/bin/vim
mv: overwrite `/usr/bin/vim'? yes
```

5. 소유자 및 권한 설정

파일의 소유자와 그룹을 root 로 변경한 후, 권한을 rwxr-xr-x 으로 설정하여 관리자는 실행과 수정 가능하게 하고 일반 사용자는 실행만 가능하게 설정한다.

```
[root@localhost roror]# chown root:root /usr/bin/vim
[root@localhost roror]# chmod 755 /usr/bin/vim
```

6. 정상 여부 확인

권한 및 소유자 정상적으로 적용되었는지 확인한다.

```
[root@localhost roror]# ls -l /usr/bin/vim
-rwxr-xr-x. 1 root root 8544  4월   7 18:19 /usr/bin/vim
```